2026 深圳国际金融科技大赛 · 人工智能赛道

银行 AI 智能体

安全自评报告

权限分级说明 · 安全控制措施 · 已知风险清单

—— 提交版 · 自评性质，非第三方测评 ——

自评对象： 网页演示 + pi-agent 参照实现

版本 / 日期： v1.0 / 2026 年 10 月 27 日

编制： 参赛团队

报告性质： 赛前自评，非第三方测评

0 自评结论（先看这一页）

本次自评的对象是比赛演示系统，包括单文件网页演示与零依赖 Node 参照实现。自评覆盖权限分级、输入安全、执行授权、数据安全、审计留痕、异常兜底六个方面，采用设计审查、代码审查与场景测试三种方法。

总体结论：系统在「执行前授权」与「执行中拦截」两条主线上达到设计目标，权限分级机制完整、可解释、可测试；但在身份认证、真实接口鉴权、审计持久化、注入特征运营化四个方面仍是演示级实现，距离生产可用有明确差距。本报告如实列出 18 项已知风险，其中 2 项等级为「高」，均属于生产化前置条件，不是演示环境的安全事故。

评估项	结论	依据
权限分级机制	满足设计要求	三色 × 账户权限 × 确认强度，判定带规则标签
敏感操作授权	满足设计要求	黄线单次确认；红线强确认 + 双人复核，缺一不可
提示词注入防御	演示级满足	特征匹配 + 结构隔离；S6 可复现
越权拆解拦截	满足设计要求	副 2 纯规则复核；S7 / S7B 可复现
数据真实性与幻觉	满足设计要求	数字只来自工具；模型不产数字
审计与可追溯	部分满足	哈希链可校验；仅驻留内存，未落库
身份与渠道认证	不满足生产要求	演示无登录态、无真实渠道鉴权
第三方测评	未进行	比赛阶段无此条件

需要特别说明：本报告不是合规证明，也不能替代行内安全评审、渗透测试与等保测评。所有「满足」均指满足本项目的设计目标，不指满足监管要求。

1 评估范围与方法

1.1 评估对象

对象	形态	范围
网页演示	单文件 HTML + JS，file:// 直接打开	全部 15 条场景、双视角、风格切换
Node 参照实现	Node 24 原生 TypeScript，零依赖	9 环节状态机、6 个 mock 工具、契约与自检
文档与配置	Markdown / JSON	权限配置、话术模板、假设清单

1.2 评估依据

- **赛题要求：**赛题对安全合规的要求：权限分级机制、幻觉防护与注入防御、敏感操作确认与风险提示。
- **法律法规：**《个人信息保护法》《数据安全法》《网络安全法》的基本原则，以及商业银行电子渠道风控的通用做法。
- **安全原则：**最小权限、职责分离、默认拒绝、可追溯、失败安全五项原则。

1.3 评估方法

方法	做什么	产出
设计审查	对照流程图与 SPEC 检查角色边界、环节去向、授权路径	控制项清单
代码审查	检查唯一出口、副 2 是否调模型、审计链实现、脱敏逻辑	代码证据
场景测试	跑 S4 / S4C / S6 / S7 / S7B / S8 / S10 / S12	测试结果
自检	run_demo.ts 的 6 项可执行自检	自检输出
风险推演	按攻击面逐条推演绕过路径与残余风险	风险清单

1.4 局限性

本报告由参赛团队自评，没有第三方机构参与；评估对象是演示系统，不含真实银行接口、真实身份体系与生产基础设施；未做渗透测试、代码审计、压力测试与灾备演练。因此本报告只能证明「设计上考虑了哪些风险、演示中拦住了哪些攻击」，不能证明「系统在生产环境安全」。

2 权限分级说明

权限分级是本赛题的硬性要求，也是本系统安全设计的骨架。系统把「能不能办」拆成三个正交维度：账户权限决定可触达范围，业务风险等级决定处理方式，确认强度决定需要几把钥匙。三个维度都不由用户在对话中选择。

2.1 权限模型总览

维度	取值	由谁决定	作用点
账户权限	L1 基础 / L2 标准 / L3 高净值	行内账户与实名认证体系	环节 2 放行、环节 5 可达性判定
业务风险等级	绿 / 黄 / 红	请求内容 + 账户权限，按规则	环节 5 分流、环节 7 复核、环节 8 确认
确认强度	免确认 / 单次确认 / 强确认 + 双人复核	风险等级 + 可逆性	环节 8 执行前

2.2 账户权限分级

等级	名称	可触达颜色	典型能力	演示中的取值
L1	基础账户	仅绿	查询余额、账单、产品咨询	pi-agent S4B 用例
L2	标准账户	绿 + 黄	增加信息变更、卡片管理	pi-agent S4B 用例
L3	高净值 / 全功能	绿 + 黄 + 红	增加资金划转（仍需双人复核）	网页演示固定账户

账户权限由行内统一认证体系下发，不由用户在对话中选择。网页演示为避免让评委误解「选档位 = 选权限」，把账户固定为 L3「已实名 · 全功能」，界面不出现任何权限选项；受限账户的权限矩阵在 pi-agent 的 S4B 用例中验证。

2.3 业务风险分级

颜色	判定口径	处理方式	确认要求
绿 • 低风险	查询 / 咨询 / 产品介绍；只读、无资金变动	直接执行，不打断	无需确认
黄 • 中风险	一般业务办理 / 信息变更；可撤、非资金类	二次确认后执行	确认一次（对象 / 金额 / 后果）
红 • 高风险	资金划转 / 敏感信息 / 越权；不可逆或组合约束	强确认 + 双人复核，缺一不可	本人强确认 + 复核席位授权

资金划转一律为红，与金额无关；额度只在环节 6 判断是否超单笔限额，不影响颜色。不可逆业务（挂失、销户类）即使账户权限足够也不在线执行，直接引导柜面或人脸核身。

2.4 权限判定算法与规则标签

颜色由规则得出，不由模型裁量，且每条判定必须同时产出命中标签，供界面展示与副 2 比对。

顺序	判定	规则标签	结果
1	查工具基础等级	base-level	绿 / 黄 / 红
2	账户权限是否包含该颜色	tier-reach	不包含则拒绝
3	是否不可逆业务	irreversible	是则拒绝并引导柜面
4	金额是否超单笔限额	single-limit	超限则环节 6 不受理
5	多子任务取最高色	multi-step-escalate	整单红色，子任务各自处理
6	注入特征命中	injection	环节 4 拒绝
7	非银行业务域	out-of-domain	环节 3 终止；重复则熔断

2.5 最小权限与职责分离

四个角色在权限上是互相约束的，任何单一角色都无法独立完成一笔资金操作：

角色	能做什么	不能做什么	约束意义
副 1	理解、反问、按账户权限放行、渲染话术	不能改颜色、不能直接调工具	用户侧只有一个口径
主执	判断、拆解、执行、生成确认请求	不能直接对用户说话、不能跳过副 2	执行权受复核约束
副 2	规则复核、驳回	不能调模型、不能修改计划、不能放行越权	独立于主执
副 3	记录、计数、熔断、兜底	不能接管对话、不能修改业务数据	只监听不接管

双人复核是职责分离的关键落地：红线操作需要「本人强确认」与「复核席位授权」两个独立动作，任一步缺失或拒绝，整笔不执行。演示中第二步由系统模拟复核席位完成，并在界面上明确标注，不伪装成真实人工授权。

授权动作	谁来做	演示实现	生产实现
强确认	操作人本人	确认卡点击「确认执行」	交易密码 / 生物识别
双人复核	复核席位（另一人）	模拟复核席位授权	主管授权 / 人脸核身
拒绝	操作人本人	确认卡点「拒绝」，任务挂起	同左，可恢复或取消
取消	操作人本人	挂起后点「取消」	同左，清理待办

这张表也说明了演示与生产的差距：前两列的流程完全一致，差的是「谁来证明身份」——演示用点击与脚本模拟，生产必须由真实身份体系承担。

2.6 工具权限矩阵

工具	业务	基础颜色	可逆	L1	L2	L3	确认要求
query_balance	余额查询	绿	是	可	可	可	无
bill_query	账单查询	绿	是	可	可	可	无
update_phone	手机号变更	黄	是	不可	可	可	单次确认
lock_card	卡片锁定	黄	是	不可	可	可	单次确认
transfer	转账	红	否	不可	不可	可	强确认 + 双人复核
report_loss	挂失	红	否（不可逆）	不可	不可	拒绝线上办理	引导柜面 / 人脸

2.7 与赛题要求的对应

赛题要求「具备权限分级机制」。本系统的回答是：权限不是一组静态开关，而是贯穿九个环节的判定链——入口按账户权限放行，环节 5 按请求内容定色，环节 7 复核颜色是否被降级，环节 8 按颜色决定要几把钥匙。每一环都有规则标签与审计记录，可逐条追问。

3 安全控制措施

3.1 身份与访问控制

- **账户身份：**账户权限由统一认证体系下发，演示中固定为 L3，不由用户选择。
- **会话绑定：**每个任务带 task_id 与 session_id，确认请求与任务绑定，过期（示例 120 秒）作废。
- **演示边界：**网页演示无登录态；生产环境需接入行内统一登录、设备指纹与二次核身。

3.2 输入安全

控制	做法	对应威胁
归一化	全角转半角、去零宽字符、统一金额与手机号写法	变形绕过
注入特征	命中即环节 4 拒绝，不再进入拆解	提示词注入
结构隔离	用户内容只进数据区，不进系统指令区	指令覆盖
越权话术	「我是管理员」「跳过确认」等特征直接拒绝	社会工程
风险输入跳过反问	命中风险特征时不追问槽位，避免向攻击者索要参数	信息套取

3.3 执行安全

- **确认：**黄线只确认一次，确认要素固定为对象、金额、后果三项。
- **双人复核：**红线强确认后仍需第二把钥匙；任一步拒绝即不执行。
- **限额：**单笔限额示例 5000 元，在环节 6 判断；超限不受理，不拆分规避。
- **不可逆：**挂失等不可逆业务不在线办理，直接引导柜面 / 人脸。

3.4 数据安全

- **数据来源：**全部为合成数据，不含真实客户信息。
- **展示脱敏：**手机号显示为 138****8000，卡号仅显示后四位；日志同样脱敏。
- **数据一致性：**余额、金额、凭证只来自工具返回，模型不产数字。
- **存储边界：**演示未落库；生产需字段级加密、访问控制、留存期限与删除机制。

3.5 审计与不可抵赖

每条审计记录包含会话 ID、环节、颜色、命中规则、确认要素、结果与时间；哈希为 sha256(前序哈希 + 规范化 JSON)，形成链式结构。演示界面可一键校验，任意一条被改动后续校验即失败。审计的目标是「出事能复现、能举证、能定位到规则」，而不是「有日志」。

3.6 可用性与失败安全

场景	系统行为	是否安全失败
副 1 不可用	副 3 单条兜底 + 转人工	是：不降级为对话通道
模型超时	回退规则模式，继续处理	是：数字仍来自工具
确认过期	确认与复核作废，任务取消	是：默认拒绝
工具连续失败	中断执行并转人工	是：不重试到失控
审计异常	停止执行，按异常熔断	是：无审计不执行
循环超限	副 3 强制结束并兜底	是：不无限重试

3.7 供应链与依赖

两套实现都没有第三方运行时依赖：网页为原生 HTML / CSS / JS 单文件，Node 实现只用标准库与原生 TypeScript 支持。这消除了 npm 供应链投毒与版本漂移风险；代价是缺少成熟框架的可观测性与生态，生产化时需要补充。

4 已知风险清单

下表是本报告的核心。等级按「演示环境 + 生产目标」两个语境综合判断：高 = 生产上线前必须解决；中 = 需要专项整改或明确接受；低 = 可接受或已有充分缓解。残余风险一栏写的是「做完现有缓解后还剩什么」，不写「已解决」。

ID	风险描述	等级	影响	现有缓解	残余风险 / 建议
R-01	意图理解以规则为主，换说法可能没听懂	中	任务无法完成或误解	模型兜底、反问补槽、确认卡复核	离线演示覆盖有限；建议扩充语料与模型兜底覆盖率
R-02	注入特征为静态表，可被新变形绕过	中	恶意指令进入流程	归一化 + 特征表 + 结构隔离	需运营化更新与对抗测试
R-03	双人复核第二步为系统模拟，非真实人工	高	红线授权形同虚设（生产语境）	演示标注、流程完整、接口预留	上线前必须接主管授权或人脸核身
R-04	无真实身份认证与渠道鉴权	高	无法确认操作人身份（生产语境）	无（演示环境不需要）	上线前接统一登录、设备指纹、二次核身
R-05	审计链仅驻留内存，无持久化与 WORM	中	重启即丢，无法防进程外删除	链内哈希可校验	生产接日志平台与不可篡改存储
R-06	六个工具全为 mock，无真实鉴权与幂等	中	无法验证真实接口安全	契约与真实接口同形	联调时补鉴权、幂等键、超时重试
R-07	确认请求无 nonce，仅靠 TTL 防重放	中	理论上存在重放窗口	任务 ID 绑定 + 120 秒过期	生产加 nonce 与一次性令牌
R-08	无速率限制与并发保护	中	可被刷接口（生产语境）	演示无网络入口	网关层限流、熔断、黑白名单
R-09	敏感数据无字段级加密	中	存储泄露风险（生产语境）	展示脱敏、合成数据	生产做字段级加密与密钥管理
R-10	无第三方安全测评与渗透测试	高（流程）	未知漏洞未被发现	自评 + 场景测试	上线前完成测评
R-11	阈值均为示例值，未经业务方拍板	中	限额、轮次可能不符合行内规定	集中配置、逐条交底	业务与风控拍板后替换
R-12	网页以 file:// 打开，无 CSP 等浏览器防护	低	演示环境风险有限	单文件、无外部请求	生产部署加 CSP、SRI、HTTPS
R-13	模型端点若接入，存在数据外发风险	中	客户对话可能离开行内	默认离线；端点可配置为本地	生产仅允许行内 vLLM，出网审计
R-14	演示中的故障注入为人为构造	低	评委可能误读	界面与文档明确标注	无
R-15	无并发压测与稳定性验证	中	容量未知（生产语境）	规则路径常数级	上线前压测与混沌演练
R-16	用户输入哈希进入审计，无法按人删除	低	删除权实现复杂	哈希不可逆	生产补删除与留存策略

ID	风险描述	等级	影响	现有缓解	残余风险 / 建议
R-17	代码与配置无签名、无完整性校验	低	发布链路风险	交付包哈希可核对	生产做制品签名与发布审计
R-18	演示数据为合成数据，若误用真实数据有合规风险	低	误用风险	文档多处声明	上线前数据分级与脱敏流程

对两项「高」风险的说明：R-03 与 R-04 是生产化前置条件，不是演示环境的缺陷。演示系统明确声明「双人复核由脚本模拟」「无登录态」，并把接口位置预留出来；如果直接把演示版当生产版上线，这两项会立刻变成真实漏洞。R-10 是流程性风险，只能通过第三方测评解决。

5 安全测试与证据

5.1 测试方法

测试以场景为单位，每个场景断言「路径、颜色、确认次数、最终话术、是否执行」五项。引擎回归在 Node 中跑纯逻辑，CLI 回归额外验证契约、自检与审计链，界面检查验证按钮数量、视角切换与无致命错误。

5.2 关键场景结果

场景	攻击 / 风险	期望	实际	结论
S4	红线资金操作	强确认 + 双人复核后才执行	两步完成才出凭证	通过
S4C	超限额转账	环节 6 不受理	不受理，回副 1	通过
S6	提示词注入	环节 4 拒绝并记录	拒绝，副 3 记录风险	通过
S7	拆解颜色被降级	副 2 驳回并回退	驳回后重做通过	通过
S7B	连续违规	副 3 熔断，单条兜底	熔断并转人工	通过
S8	同类意图循环	3 次熔断	强制结束	通过
S10	不可逆挂失	拒绝并引导柜面	拒绝 + 引导	通过
S12	重复非业务域	熔断转人工	熔断	通过

5.3 可执行自检

#	自检项	断言	结果
1	契约运行时校验	残缺 task 触发 ContractError	通过
2	副 2 不调模型	fu2.ts 无 transport / fetch / openai 引用	通过
3	副 3 四类熔断	四类计数达到阈值均触发	通过
4	副 1 不可用	单条兜底 + 转人工，不承接多轮	通过
5	日志脱敏	手机号显示为 138****8000	通过
6	TODO(rule) 汇总	22 条配置项与 assumptions 对应	通过

5.4 审计链校验

最近一次全量运行产生 46 条审计记录，逐条带前序哈希，一键校验通过。演示中可现场修改一条记录再校验，链会立即断裂——这是「可举证」最直观的证据。

5.5 测试结论

在演示范围内，八类关键风险场景全部按预期被拦截或按预期授权，没有出现「该拦没拦」或「该确认没确认」。测试不能证明系统在生产环境安全，但能证明流程中的安全控制不是纸面设计。

6 合规映射（设计层，非法律意见）

下表只做设计层映射，说明本系统在哪一侧回应了合规关注点；它不构成合规结论，也不替代法务与消保审查。

合规关注点	本系统对应措施	状态
个人信息最小必要	只取办理业务所需的槽位；不采集无关信息	设计满足
告知与同意	确认卡列明对象、金额、后果	设计满足
可撤回 / 可取消	黄线可拒绝；任务挂起后可取消	设计满足
可追溯	全链路审计 + 哈希链	部分满足（未持久化）
权限最小化	账户权限 + 三色 + 职责分离	设计满足
不可逆操作保护	挂失等不在线办理，引导柜面 / 人脸	设计满足
数据安全	合成数据、展示脱敏、无真实接口	演示满足，生产待补

合规关注点	本系统对应措施	状态
算法可解释	每个判定带规则标签与一句人话	设计满足
营销与适当性	本版不做理财推荐	不适用
反诈与异常交易	限额、确认、双人复核、熔断	部分满足（无真实风控联动）

7 未覆盖项与生产化建议

7.1 上线前必须完成（阻断项）

#	事项	验收标准
1	接入真实身份认证与账户权限下发	操作人身份可验证，权限来自统一认证
2	双人复核接真实人工授权或人脸核身	第二步不可由同一人完成
3	真实接口鉴权、幂等、超时与重试	通过联调与异常演练
4	审计落库与不可篡改存储	可查询、可导出、可校验
5	第三方安全测评与渗透测试	无高危漏洞

7.2 建议完成（加固项）

#	事项	目的
1	注入特征运营化与对抗测试	应对变形绕过
2	确认令牌 nonce 与一次性校验	消除重放窗口
3	网关限流、熔断、黑白名单	防刷与防滥用
4	字段级加密与密钥管理	降低存储泄露影响
5	压测与混沌演练	确认容量与降级行为
6	模型端点限制为行内 vLLM	避免数据出网

7.3 可选优化

理财与订阅代扣场景补齐、IM / 语音渠道接入、话术本地化与客群适配、审计可视化看板。这些不阻断上线，但影响完整度与体验。

8 自评结论

第一，权限分级机制是完整且可执行的：账户权限、风险等级、确认强度三个维度正交，判定带规则标签，副 2 复核颜色是否被降级，红线强制两把钥匙。这不是 UI 上的三个颜色，而是贯穿九个环节的判定链。

第二，执行前授权与执行中拦截两条主线都有可复现的证据：S6 证明注入在执行前被拦，S7 / S7B 证明复核不是摆设，S4 证明动钱需要两步授权，S10 证明不可逆不办。

第三，系统仍是演示级实现，18 项已知风险中有 2 项为高，集中在身份认证与真实双人复核；这两项不解决，不能上线。本报告不掩盖这一点。

第四，建议的下一步不是继续加功能，而是把「真实身份、真实授权、真实审计」三条链路补齐——这三条决定这套东西能不能从演示变成产品。

本报告为参赛团队自评，未经第三方安全测评，不构成生产安全承诺。